

Case Study Analysis: Disclosure of Sensitive Personal Data by a Hospital to a Third Party

Abinel Madzivire

Introduction

This analysis examines Case Study 5, 'Disclosure of sensitive personal data by a hospital to a third party', reported by the Irish Data Protection Commissioner (DPC) in its 2017 Annual Report (Data Protection Commissioner, 2018). The case concerns the accidental disclosure of a patient's medical information after correspondence containing medical reports was incorrectly addressed and delivered to the patient's neighbour.

Although the incident preceded the application of the General Data Protection Regulation (GDPR), the case remains highly relevant to contemporary data-protection practice because it concerns fundamental principles subsequently reinforced by the GDPR, particularly accuracy, integrity and confidentiality, security of processing, accountability and the heightened protection afforded to health information.

What specific aspect of GDPR does the case study address?

The case arose after a patient attended a hospital for medical procedures. Medical reports relating to those procedures were subsequently sent in an envelope that was incorrectly addressed. The address combined the name of the patient's General Practitioner (GP), elements of the GP's address and the home address of the patient's neighbour. The neighbour received and opened the correspondence and consequently viewed the patient's medical information (Data Protection Commissioner, 2018).

The principal GDPR issue illustrated by the case is therefore the unauthorised disclosure of personal data and failure to maintain its confidentiality. Article 5(1)(f) of the GDPR requires personal data to be processed in a manner that ensures appropriate security, including protection against unauthorised processing, accidental loss or disclosure through appropriate technical and organisational measures (European Parliament and Council, 2016).

The case is particularly significant because the information concerned medical records. Health information constitutes special category personal data under Article 9 GDPR and consequently requires greater protection because inappropriate disclosure may have substantial consequences for an individual's privacy, dignity and fundamental rights.

The incident also illustrates the accuracy principle contained in Article 5(1)(d). Organisations must take reasonable steps to ensure that personal data are accurate and, where necessary, kept up to date. In this case, inaccurate combination and transcription of address information directly contributed to the disclosure.

Furthermore, Article 32 requires controllers and processors to implement technical and organisational security measures appropriate to the level of risk associated with their processing activities (European Parliament and Council, 2016). This includes regularly assessing and evaluating whether security controls remain effective. The incident demonstrates that information security encompasses not only sophisticated cyberattacks but also administrative procedures governing physical correspondence.

How was the case resolved?

Following the complaint, the hospital acknowledged that the patient's medical information had inadvertently been sent to the incorrect address and apologised. Its

investigation established that its normal procedure was to send medical reports to GPs using windowed envelopes. However, on this occasion a member of staff departed from the established procedure and used a non-windowed envelope with a manually written address. In doing so, the employee incorrectly combined elements of the GP's and patient's address information (Data Protection Commissioner, 2018).

Following the incident, administrative staff were briefed on the correct procedure for issuing medical reports and the hospital decided that non-windowed envelopes would no longer be used for this purpose.

The patient rejected an offer of amicable resolution and requested a formal determination. The Commissioner subsequently found that the hospital had breached provisions of the Data Protection Acts 1988 and 2003 concerning accuracy, appropriate security measures and the processing of sensitive personal information (Data Protection Commissioner, 2018).

An important lesson identified by the Commissioner was that the incident resulted from what appeared to be a relatively minor departure by one employee from an established procedure. Nevertheless, that deviation resulted in highly sensitive medical information being accessed by an unauthorised third party. The Commissioner considered that appropriate quality-control and oversight arrangements could probably have prevented the incident.

What would I do as the Information Security Manager?

If this occurred within my organisation, I would avoid treating the incident simply as an isolated case of human error. The employee's mistake was the immediate cause, but effective information-security management should also consider why organisational controls allowed a single administrative error to result in unauthorised disclosure.

1. Conduct a formal incident and root-cause investigation

My first action would be to establish precisely what happened, what information was disclosed, who received it, whether further copies existed and whether other patients might have been affected by the same process.

The investigation should distinguish between the immediate cause — incorrect addressing — and underlying control weaknesses, including inadequate checking, insufficient supervision or ineffective enforcement of established procedures.

2. Conduct a GDPR breach-risk assessment

The organisation should assess the likely impact upon the affected data subject. Because medical information is special category data, its unauthorised disclosure could create significant privacy and confidentiality risks.

Where the legal threshold is satisfied, appropriate breach-notification procedures should be followed. The affected individual should also receive clear information explaining what happened, the information involved, potential consequences and measures taken to mitigate the incident.

3. Introduce a verification process for sensitive correspondence

I would establish a mandatory verification process before confidential medical correspondence leaves the hospital. For particularly sensitive documentation, a second authorised member of staff could verify the recipient details against the patient or GP record.

Where feasible, addresses should be generated automatically from validated electronic records rather than manually transcribed. This would reduce opportunities for human error.

4. Strengthen technical and organisational controls

Article 32 GDPR requires security measures appropriate to risk. Consequently, controls should address both digital and physical information.

The organisation should consider secure electronic communication channels for transferring medical reports to authorised healthcare professionals, where appropriate. Where physical correspondence remains necessary, standardised procedures should govern printing, addressing, sealing, checking and dispatch.

Access to medical information should additionally follow the principle of least privilege so that employees can access only the information required to perform their duties.

5. Provide role-specific data-protection training

Generic annual GDPR training would be insufficient on its own. Staff handling medical records should receive practical training covering confidentiality, special category data, secure communications, verification of recipients and procedures for reporting suspected breaches.

The case demonstrates why policies alone cannot guarantee compliance. Employees must understand how those policies apply to everyday activities.

6. Implement monitoring, auditing and quality assurance

I would introduce periodic audits of processes involving sensitive information. This could include sampling outgoing correspondence to determine whether verification procedures are being followed.

Article 32 specifically recognises the importance of regularly testing and evaluating the effectiveness of security measures. Therefore, management should seek evidence that controls operate effectively rather than merely documenting their existence.

7. Embed data protection by design and by default

Finally, I would redesign the process according to the GDPR principle of data protection by design and by default. Rather than relying primarily upon employees to avoid mistakes, the process should make incorrect disclosure inherently more difficult.

For example, automated recipient verification, standardised templates, electronic transfer systems, restricted access and exception alerts could create multiple layers of protection. This represents a defence-in-depth approach in which the failure of one control does not automatically result in disclosure.

Conclusion

This case demonstrates that serious data breaches do not necessarily result from sophisticated cyberattacks. A seemingly straightforward administrative error resulted in sensitive medical information being disclosed to an unauthorised third party. The case therefore highlights the importance of accuracy, confidentiality, appropriate security and organisational accountability.

From an Information Security Manager's perspective, simply retraining the individual responsible would not provide an adequate long-term response. The organisation should investigate the root cause, strengthen verification procedures, improve staff awareness, automate processes where appropriate and regularly test the effectiveness of its controls.

The wider lesson is that human error should be anticipated rather than assumed to be completely preventable. Effective information security should therefore combine trained personnel with technical safeguards, standardised processes, monitoring and management oversight. For organisations processing health information, such defence-in-depth is particularly important because a confidentiality breach can cause

significant harm to the privacy and trust of the individuals whose information the organisation is responsible for protecting.

References

Data Protection Commissioner (2018) *Annual Report of the Data Protection Commissioner of Ireland 2017*. Dublin: Office of the Data Protection Commissioner.

European Parliament and Council (2016) 'Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)', *Official Journal of the European Union*, L119, pp. 1–88.

E-Portfolio Reflection: GDPR Case Study

This activity strengthened my understanding that information-security incidents are not always caused by sophisticated cyberattacks or technical vulnerabilities. The Data Protection Commission case demonstrated how a relatively simple administrative error resulted in sensitive medical information being disclosed to an unauthorised individual. This reinforced the importance of considering people, processes and technology together when managing information-security risks.

A particularly important lesson for me was the relationship between human error and organisational responsibility. Although an employee incorrectly addressed the correspondence, effective information-security management should not depend entirely upon individuals performing every task without error. Organisations should implement multiple safeguards, including clear procedures, verification mechanisms, staff training, monitoring and appropriate technical controls.

The activity also developed my understanding of the GDPR principles of accuracy, integrity and confidentiality and the additional protection required when processing special category data such as health information. I recognised that GDPR compliance should not simply involve producing policies and delivering annual training. Organisations must demonstrate that appropriate controls are implemented, monitored and regularly evaluated for effectiveness.

From the perspective of an Information Security Manager, I would adopt a defence-in-depth approach in which a single human error would be less likely to result in a data breach. This could include automated recipient verification, secure electronic communication, access controls, quality-assurance checks, incident-response procedures and periodic auditing.

Overall, this activity has developed my understanding of the relationship between data protection, information security and organisational risk management. I will apply this learning to future cybersecurity risk assessments by considering not only technical vulnerabilities but also human behaviour, business processes and the effectiveness of organisational controls.

Reference

Data Protection Commissioner (2018) *Annual Report of the Data Protection Commissioner of Ireland 2017*. Dublin: Office of the Data Protection Commissioner.

European Parliament and Council (2016) 'Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 (General Data Protection Regulation)', *Official Journal of the European Union*, L119, pp. 1–88.